

# SummitCrowd Markets LLC

## Cybersecurity Incident and Customer Data Procedures

---

|                |                                           |
|----------------|-------------------------------------------|
| Document owner | Head of Operations and Compliance         |
| Approved by    | Chief Executive Officer                   |
| Effective date | October 6, 2025                           |
| Version        | 1.4                                       |
| Classification | Internal Policy - Fictional Test Document |

This fictional document is part of the RegSpan realistic testing corpus. It is written as an ordinary company policy, not as a model answer or legal opinion.

## Document Control

| Version | Effective date  | Summary of change      | Approval                |
|---------|-----------------|------------------------|-------------------------|
| 1.4     | October 6, 2025 | Current approved issue | Chief Executive Officer |

## Policy Overview

SummitCrowd operates an online funding portal using cloud hosting, identity-verification services, payment processors, and customer-support vendors.

The sections below describe the firm's approved practices. Department procedures may provide additional implementation detail.

### 1. Purpose, Scope, and Applicability

SummitCrowd operates an online funding portal using cloud hosting, identity-verification services, payment processors, and customer-support vendors.

This document establishes the firm's internal approach to protecting customer information and responding to information-security events. It applies to employees, temporary personnel, contractors, offices, information systems, paper records, and relevant service-provider relationships.

Business units may maintain more detailed procedures, but those procedures may not reduce the protections stated here. Legal and Compliance interpret regulatory obligations and resolve conflicts with other retention, privacy, cybersecurity, or contractual requirements.

### 2. Definitions

| Term                           | Working definition                                                                                                                                                                                                                       |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Customer information           | A record containing nonpublic personal information about a customer of a financial institution, including information handled by or on behalf of the firm and information provided by another financial institution about its customers. |
| Sensitive customer information | Customer information whose compromise could create a reasonably likely risk of substantial harm or inconvenience to an identified individual.                                                                                            |
| Customer information system    | Information resources and related infrastructure used to collect, process, maintain, use, share, disseminate, or dispose of customer information.                                                                                        |
| Service provider               | A person or entity that receives, maintains, processes, or is permitted access to customer information through services provided directly to the firm.                                                                                   |
| Incident                       | Unauthorized access to or use of customer information, or an event reasonably likely to involve such access or use.                                                                                                                      |

### 3. Roles and Responsibilities

| Role                              | Core responsibilities                                                          |
|-----------------------------------|--------------------------------------------------------------------------------|
| Executive sponsor                 | Provides authority, resources, and escalation support.                         |
| Incident Response Lead            | Directs triage, response activities, documentation, and closure.               |
| Information Security / Technology | Investigates, contains, restores, and validates systems.                       |
| Compliance and Legal              | Interprets notice, recordkeeping, regulatory, and law-enforcement obligations. |
| Business and data owners          | Identify affected processes, systems, information, and customers.              |
| Service-provider owner            | Coordinates vendor evidence, notices, remediation, and follow-up.              |
| Communications / Customer Service | Prepares approved customer communications and handles inquiries.               |

### 4. Cyber Incident Response Governance

SummitCrowd Markets LLC maintains procedures for handling cybersecurity events and suspected misuse of firm systems. Employees report events to the designated response coordinator, who opens a ticket and works with technology and compliance personnel.

The procedures address investigation, escalation, restoration of important services, and communication with management. Customer information events follow the same general workflow used for other cybersecurity incidents.

### 5. Assessment, Containment, and Control

For every suspected incident involving unauthorized access to or use of customer information, the response team assesses the nature and scope of the incident. The assessment identifies the date and method of access, affected accounts and users, duration, privileges obtained, systems involved, and whether data was viewed, copied, altered, transmitted, or destroyed.

The assessment must identify each customer information system that may have been affected and the types of customer information stored or processed in those systems. The team records whether sensitive customer information may be involved and identifies affected individuals when reasonably possible.

- isolate compromised hosts, accounts, applications, or network segments;
- disable or reset credentials and rotate keys or tokens;
- block malicious infrastructure and preserve monitoring;
- search for additional affected systems and unauthorized persistence;
- coordinate controlled shutdowns when needed to prevent further unauthorized access or use.

### 6. Third-Party Security and Breach Escalation

The firm maintains and enforces written procedures for due diligence and ongoing monitoring of service providers that receive, maintain, process, or are permitted access to customer information. Reviews consider security controls, incident-response capability, subcontractor use, independent assurance reports, material changes, and known control failures.

Oversight is reasonably designed to ensure that service providers protect against unauthorized access to or use of customer information and notify the firm as soon as possible, but no later than 72 hours after becoming aware that a breach in security resulted in unauthorized access to a customer information system maintained by the provider.

Upon receipt of a qualifying provider notice, or upon independent detection of the incident, the firm immediately initiates its incident response program. A provider may deliver customer notices under a written agreement, but the firm remains responsible for ensuring that each required notice satisfies the firm's obligations and is timely delivered.

- document initial and periodic due diligence;
- track identified risks and remediation;
- maintain provider breach notices and related communications;
- verify completion and delivery when a provider sends customer notices on the firm's behalf.

## 7. Customer Breach Notification Procedure

Legal evaluates customer notification after unauthorized access to sensitive customer information. The goal is to send notice as soon as practical, with 30 days used as an internal target.

Legal may extend the target when the investigation remains active or material facts are still developing.

## 8. Required Customer Notice Content

Customer notices describe the incident, identify the categories of information involved, provide an estimated incident date when available, and direct customers to the firm's toll-free response line and incident email address.

The notice template also advises customers to monitor accounts and contact the firm if suspicious activity appears.

## 9. Customer Information Security Controls

Customer data is protected through access restrictions, passwords, encryption, and employee confidentiality obligations.

Managers approve access based on job responsibilities and remind personnel of confidentiality obligations during annual training.

## 10. Incident Documentation

Incident tickets document the event, assigned owner, status, and resolution.

Attachments are retained with the ticket until the ticket is archived under the support-system schedule.

## 11. Recovery, Remediation, and Validation

Technology restores affected services from backups and tracks corrective actions in the incident ticket. System owners confirm that applications are available before normal processing resumes.

The business owner confirms that the application is available and that normal processing can resume.

## 12. Books and Records

Compliance maintains the current policy, annual reviews, and records of significant incidents. Records are kept under the corporate retention schedule.

The records coordinator applies the corporate retention schedule and responds to examination requests.

## 13. Records Destruction Procedures

Employees periodically delete obsolete files and may request removal of old paper records from storage.

Department managers decide when obsolete paper and electronic files may be removed.

## 14. Legal, Regulatory, and Law-Enforcement Coordination

Only senior management may contact regulators or law-enforcement authorities. Employees should refer external inquiries to Legal.

Legal manages any follow-up with the requesting authority and informs management of next steps.

## 15. Training, Testing, and Review

Personnel receive training appropriate to their roles. Employees are trained to report suspicious access, lost devices, misdirected information, customer complaints suggesting account compromise, and unusual service-provider communications.

The policy owner reviews the document annually and may conduct a tabletop exercise when resources permit.

## Approval

|                |                                   |         |                 |
|----------------|-----------------------------------|---------|-----------------|
| Policy owner   | Head of Operations and Compliance | Date    | October 6, 2025 |
| Approving body | Chief Executive Officer           | Version | 1.4             |